LABORATUVAR 3 · MİRKA SMART WOODSANDER 5000 · Ahşap Zımpara Makinesi

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad: _____ Grup: _____ Tarih: ___/___/2026

Kavram: Senaryo beş parçadır: kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır. (L: olasılık, S: ciddiyet, E: insanın maruziyeti)

WoodSander'ın kapıları: internete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — fiziksel sonuç adayları: zımpara kafasında el-parmak yaralanması, sıkışma/sürüklenme, parça fırlaması, toz yangını.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
R1 Uzaktan saldırgan → internete açık uzak bakım modülü (admin/admin) → Safety PLC parametrelerini değiştirir (kapak kilit gecikmesi=0, standstill izleme kapalı) → operatör bakım kapağını dönen kafa varken açar → **el-parmak ağır yaralanması**.	3	3	3	**27**	**KRİTİK**
R2 Ağ içi saldırgan / kötü niyetli içeriden → port 80 HMI → sürücü parametrelerinde hız sınırı kaldırılır, besleme+kafa hızı aşırı yükseltilir → bant kopması / iş parçası fırlaması → **çalışana darbe**.	2	3	2	**12**	**YÜKSEK**
R3 Wi-Fi/USB ile giren zararlı → toz emme ünitesi ve yangın algılama sessizce devre dışı → toz birikimi + kıvılcım → **yangın/toz patlaması**, personel yaralanması.	1	3	1	**3**	**DÜŞÜK** (S=3 → öne alınır)

Kritik 18–27 | **Yüksek 9–17** | **Orta 4–8** | **Düşük 1–3**

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

R1 (skor 27, Kritik): internetten tek adımda erişilebilen, zayıf parolalı bir kapı, emniyet fonksiyonunu doğrudan etkisiz bırakıp operatörü dönen kafanın önüne çıkarıyor.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet, R3 (skor 3, Düşük ama S=3). Risk Register'a skor sırasına bakılmaksızın "**S=3 — öne alınan**" etiketiyle, kırmızı bayrak ve ayrı sütunla işlenir; yönetim özetinde Kritik'lerin hemen altında ayrı bir "Ciddiyet-3" bölümü olarak gösterilir; gözden geçirme periyodu kısa tutulur; önlem: toz emme/yangın algılama ağdan bağımsız (hardwired) izleme ve alarm.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar? (R1–R3'ün üçü de insana zarar sonucuyla bitiyor.)

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.